FEASIFY BACKEND API TEST & DISCOVERY REPORT

Document ID: FEASIFY-DOC-007
Version: 1.0.0
Date: November 10, 2026
Author: Backend & API Testing Agent (Agent 03)
Classification: API Specification & Endpoint Verification

1. API Architecture Overview

Feasify provides a dedicated companion REST API built on Express 5 (`feasify-backend/index.js`) listening on port `10000` . The API provides services for official name verification, proposal limit counting, proposal status updates, AI evaluation cascade processing, dynamic exemplar management, and audit trail extraction.

2. Comprehensive Endpoint Discovery & Test Matrix

HTTP METHOD	ENDPOINT URL	AUTH REQUIRED	PURPOSE	PAYLOAD SUMMARY	OBSERVED STATUS	VERDICT
`GET`	`/api/health`	None	Service liveness probe	None	`200 OK`	**Passed**
`POST`	`/api/name-check`	None	DTI & SEC official name verification	`{ name: string, type: string, forceRefresh: boolean }`	`200 OK` / `400 Bad Request`	**Passed**
`GET`	`/api/name-check/status`	None	Diagnostics for DTI & SEC providers	None	`200 OK`	**Passed**
`GET`	`/api/registration-sources`	None	Returns official DTI & SEC portal links	None	`200 OK`	**Passed**
`POST`	`/api/check-company-name`	None	Legacy compatibility name check	`{ companyName: string }`	`200 OK`	**Passed**
`GET`	`/api/teams/:groupId/proposals/count`	None	Query proposal count and limit ceiling (Max 3)	Route Param `:groupId`	`200 OK` (`{ count, max: 3, allowed }`)	**Passed**
`POST`	`/api/teams/:groupId/proposals`	None	Server-side proposal creation with 3-limit check	`{ title, ...proposalData }`	`201 Created` / `400 Limit Reached`	**Passed**
`PUT`	`/api/proposals/:proposalId/status`	**None (Should require Adviser token!)**	Mutate proposal status & update remarks	`{ status: string, adviserRemarks: string }`	`200 OK` (Vulnerable to unauthenticated spoofing)	**Failed (Critical Flaw)**
`GET`	`/api/exemplars/dynamic`	None	Retrieve dynamically cached academic benchmarks	None	`200 OK` (JSON array of exemplars)	**Passed**
`POST`	`/api/exemplars/evaluate-candidate`	None	Ingest approved proposal into benchmark store	`{ proposalData, financialData }`	`200 OK` / `400 Outlier Rejected`	**Passed**
`GET`	`/api/copyright-db`	None	Retrieve protected brands and school businesses	None	`200 OK`	**Passed**
`POST`	`/api/copyright-check`	None	Check brand against trademark infringement list	`{ name: string }`	`200 OK`	**Passed**

HTTP METHOD	ENDPOINT URL	AUTH REQUIRED	PURPOSE	PAYLOAD SUMMARY	OBSERVED STATUS	VERDICT
`POST`	`/api/analyze`	None (Rate-limited)	Student financial audit via Gemini cascade	`{ financialData, category }`	`200 OK` / `500 Missing API Key`	**Passed (Auth Gap)**
`POST`	`/api/analyze-proposal`	None (Rate-limited)	Adviser proposal grading via Gemini cascade	`{ businessName, productDescription, ... }`	`200 OK` / `500 Missing API Key`	**Passed (Auth Gap)**
`GET`	`/api/audit/logs`	`Bearer Token` (`verifyToken`)	Query compliance audit logs by section	Query Params `?section=...`	`200 OK` / `401 Unauthorized`	**Passed**

3. Deep-Dive Endpoint Security & Validation Analysis

3.1 Unprotected Critical Endpoint: `PUT /api/proposals/:proposalId/status`

- **Vulnerability ID:** `FEASIFY-BUG-005`
- **Severity: Critical**
- **Trace:**

```
// feasify-backend/index.js lines 773-802
app.put("/api/proposals/:proposalId/status", async (req, res) => {
  const { proposalId } = req.params;
  const { status, adviserRemarks } = req.body || {};
  // ... NO verifyToken middleware is present!
  await adminFirestore.collection("proposals").doc(proposalId).update(updatePayload);
});
```

- **Empirical Test:** Our automated test suite dispatched:

```
PUT /api/proposals/prop-101/status HTTP/1.1
Host: localhost:10000
Content-Type: application/json

{
  "status": "Approved",
  "adviserRemarks": "Unauthorized status bypass injection"
}
```

  Result: The endpoint returned HTTP `200 OK` and modified the proposal status to "Approved" in Firestore without requiring any authorization token or verifying that the caller was an authorized faculty adviser!

3.2 Unauthenticated LLM Cost Consumption: `POST /api/analyze`

- **Vulnerability ID:** `FEASIFY-BUG-007`
- **Severity: High**
- **Finding:** While protected by an IP-based rate limiter (60 req/min), an attacker can call `POST /api/analyze` repeatedly from distributed IPs, rapidly consuming the project's Google Gemini API token quota and triggering API rate limits for legitimate student users.
- **Remediation:** Apply `verifyToken` middleware and confirm that `req.user.role === "Student" || req.user.role === "Adviser"`.